

1. MITRE ATT&CK in My Own Words

its like a giant encyclopedia or cheat sheet that documents all the known techniques and tactics that real world hackers and cybercriminals use to attack systems. The name ATT&CK stands for Adversarial Tactics Techniques and Common Knowledge.

Imagine you are a security guard and you want to know all the different ways a thief might try to break into a building. MITRE ATT&CK is exactly that kind of reference guide but for cybersecurity. It was created by a non profit organization called MITRE and it is maintained and updated regularly based on real world attacks observed by security researchers around the world.

Security teams use this framework to understand how attackers think and operate, to find weaknesses in their own defenses, and to build better detection rules in their SIEM tools. It is used by SOC analysts, penetration testers, and threat hunters all over the world and it is completely free to use.

2. Three Tactics and Examples

Tactic 1: Initial Access Initial access is the first stage where the attacker tries to get into the system or network for the very first time. This is how the attacker gets their foot in the door.

Example: An attacker sends a phishing email to an employee containing a malicious link. When the employee clicks the link malware is silently downloaded onto their computer giving the attacker their first entry point into the organization's network.

Tactic 2: Credential Access Credential access is when the attacker tries to steal usernames and passwords so they can login to systems as a legitimate user and avoid detection.

Example: An attacker uses a brute force tool to repeatedly try thousands of password combinations against an SSH login page until they successfully find the correct password for an admin account. This gives them full access to the server using real credentials.

Tactic 3: Exfiltration Exfiltration is the stage where the attacker steals data from the compromised system and sends it outside the organization to their own server.

Example: After gaining access to a company's database an attacker copies thousands of customer records including names, email addresses, and credit card numbers and uploads them to a remote server they control using an encrypted connection to avoid detection.

3. Brute Force Attack Mapped to MITRE Stages

Scenario: Brute Force Attack on a Company Server

The following shows how a brute force attack like the one in our earlier log analysis maps step by step to the MITRE ATT&CK framework:

Stage 1: Reconnaissance Before attacking the attacker first gathers information about the target. They scan the internet to find open ports on the company's server and discover that port 22 which is used for SSH login is open and accessible from the internet. This tells them exactly where to attack.

MITRE Technique: Active Scanning

Stage 2: Resource Development The attacker prepares their tools for the attack. They download or set up a brute force tool such as Hydra or Medusa and prepare a wordlist containing thousands of commonly used passwords to try against the target.

MITRE Technique: Acquire Tools

Stage 3: Initial Access The attacker begins the brute force attack by pointing their tool at the server's SSH login page and rapidly trying username and password combinations. After multiple failed attempts they successfully login with the correct credentials.

MITRE Technique: Brute Force — Valid Accounts

Log evidence from our scenario: Apr 10 10:17:45 Failed password for user1 from 192.168.1.50
Apr 10 10:20:10 Accepted password for user1 from 192.168.1.50

Stage 4: Persistence After gaining access the attacker wants to make sure they can come back even if the password is changed. They create a new hidden user account or install a backdoor on the server so they always have a way back in.

MITRE Technique: Create Account — Local Account

Stage 5: Privilege Escalation The attacker was able to login as user1 which is a regular account with limited permissions. Now they try to gain administrator or root level access so they can do more damage and access sensitive areas of the system.

MITRE Technique: Exploitation for Privilege Escalation

Stage 6: Defense Evasion To avoid being detected the attacker clears or modifies the system logs so that security analysts cannot see evidence of their activities. They may also disable antivirus software or security monitoring tools.

MITRE Technique: Clear Linux or Mac System Logs

Stage 7: Exfiltration Finally the attacker copies sensitive data such as customer records, financial files, or confidential documents from the server and transfers them to their own remote server outside the organization.

MITRE Technique: Exfiltration Over C2 Channel